

Презентация по индивидуальному проекту № 5

Основы информационной безопасности

Луангсуваннавонг Сайпхачан

1. Информация

2. Выполнение работы

Раздел 1

1. Информация

1.1 Докладчик

- Луангсуваннавонг Сайпхачан

1.1 Докладчик

- Луангсуваннавонг Сайпхачан
- студент группы НКАбд-01-24

1.1 Докладчик

- Луангсуваннавонг Сайпхачан
- студент группы НКАбд-01-24
- Российский университет дружбы народов им. П. Лумумбы

1.1 Докладчик

- Луангсуваннавонг Сайпхачан
- студент группы НКАбд-01-24
- Российский университет дружбы народов им. П. Лумумбы
- <https://github.com/sayprachanh-lsvnv>

1.2 Цель работы

Научиться использовать Burp Suite.

1.3 Задание

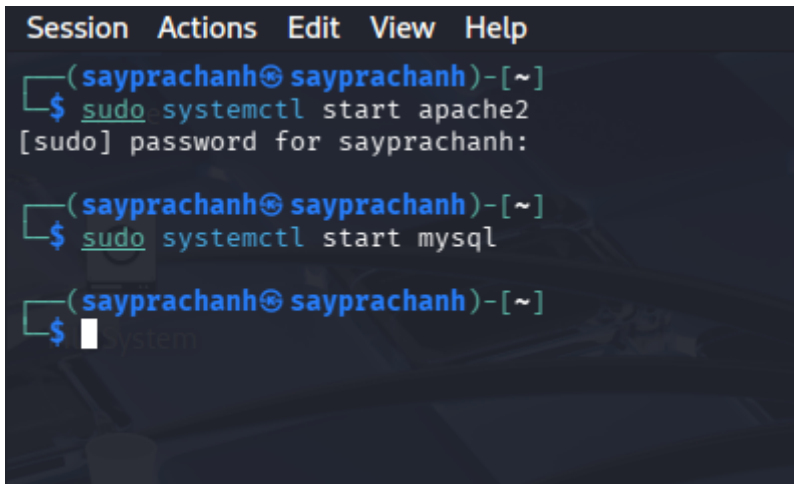
Использование Burp Suite

Раздел 2

2. Выполнение работы

2.1 Выполнение работы

Во-первых, я запускаю локальный сервер DVWA для тестирования Burp Suite.

A terminal window with a dark background and light-colored text. The window has a menu bar at the top with the items 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows three lines of command execution. The first line shows the prompt '(sayprachanh@sayprachanh)-[~]' followed by '\$ sudo systemctl start apache2'. The second line shows the prompt '(sayprachanh@sayprachanh)-[~]' followed by '\$ sudo systemctl start mysql'. The third line shows the prompt '(sayprachanh@sayprachanh)-[~]' followed by '\$' and a cursor. The background of the terminal window features a faint, stylized image of a person's face.

```
Session Actions Edit View Help
(sayprachanh@sayprachanh)-[~]
$ sudo systemctl start apache2
[sudo] password for sayprachanh:

(sayprachanh@sayprachanh)-[~]
$ sudo systemctl start mysql

(sayprachanh@sayprachanh)-[~]
$
```

Рисунок 1: Запуск локального сервера

2.2 Выполнение работы

Затем я перехожу в настройки сети браузера и настраиваю прокси так, чтобы браузер использовал тот же HTTP-прокси, что и Burp Suite.

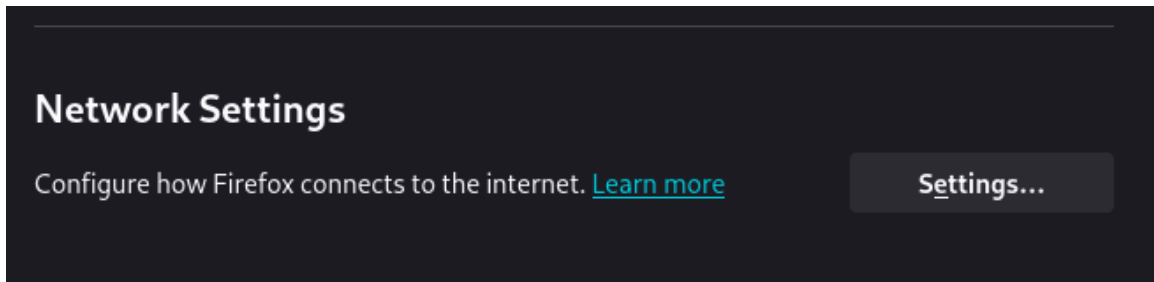
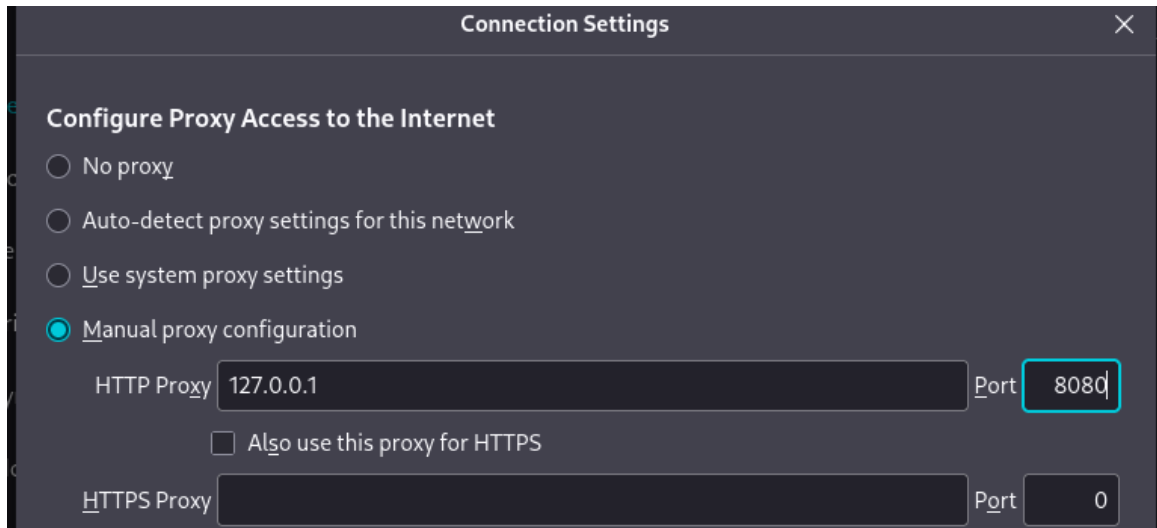


Рисунок 2: Сетевые настройки браузера

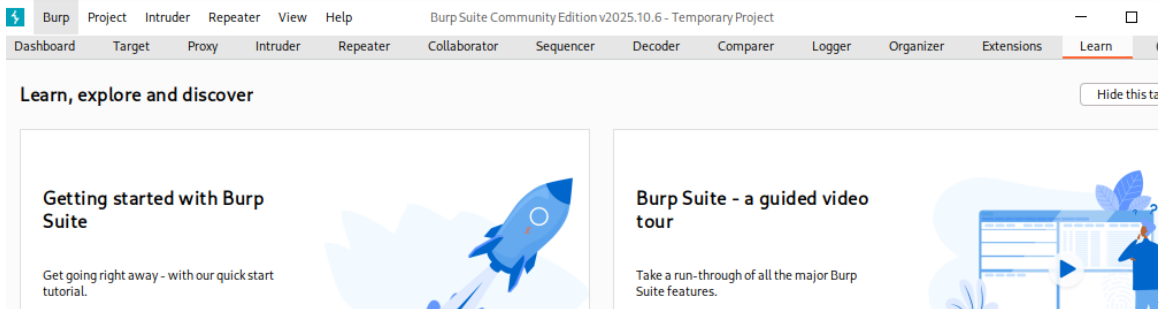
2.3 Выполнение работы



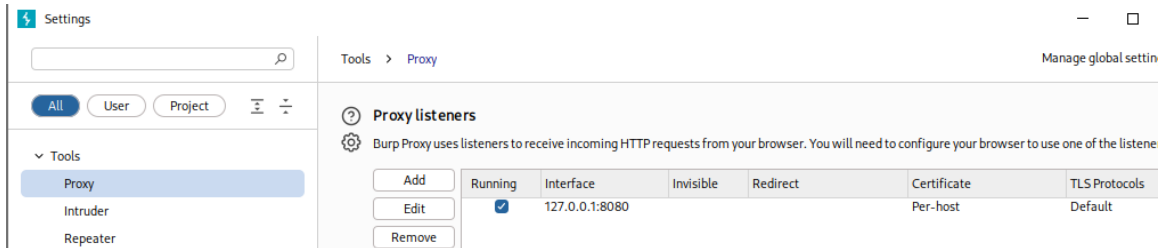
2.4 Выполнение работы

Поскольку программа Burp Suite уже предустановлена в Kali Linux, я запускаю Burp Suite сразу. Я проверяю настройки прокси, убеждаясь, что мы используем тот же прокси.

```
(sayprachanh@sayprachanh)-[~]  
$ burpsuite  
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java  
SLF4J: No SLF4J providers were found.  
SLF4J: Defaulting to no-operation (NOP) logger implementation  
SLF4J: See https://www.slf4j.org/codes.html#noProviders for further details.  
█
```



2.5 Выполнение работы



The screenshot shows the 'Proxy listeners' configuration in Burp Suite. The left sidebar contains the 'Settings' menu and a 'Tools' list with 'Proxy' selected. The main panel shows the 'Proxy listeners' section with a description and a table of active listeners.

Proxy listeners
Burp Proxy uses listeners to receive incoming HTTP requests from your browser. You will need to configure your browser to use one of the listeners.

Running	Interface	Invisible	Redirect	Certificate	TLS Protocols
☒	127.0.0.1:8080			Per-host	Default

Рисунок 5: Проверка прокси-сервера

2.6 Выполнение работы

В конфигурации браузера я устанавливаю параметр `network.allow_hijacking_localhost` в значение `true`, чтобы Burp Suite правильно работал с локальным сервером.

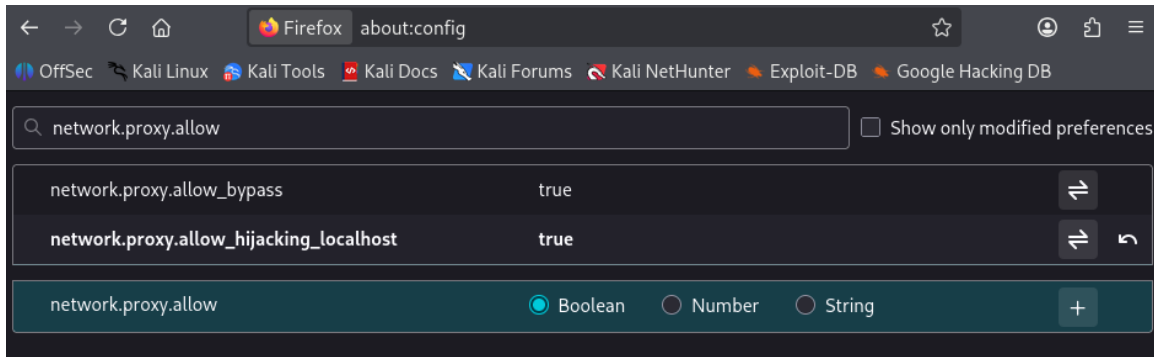
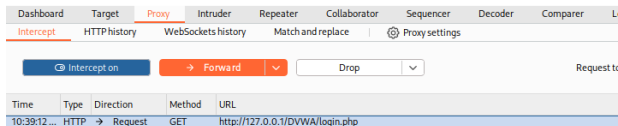


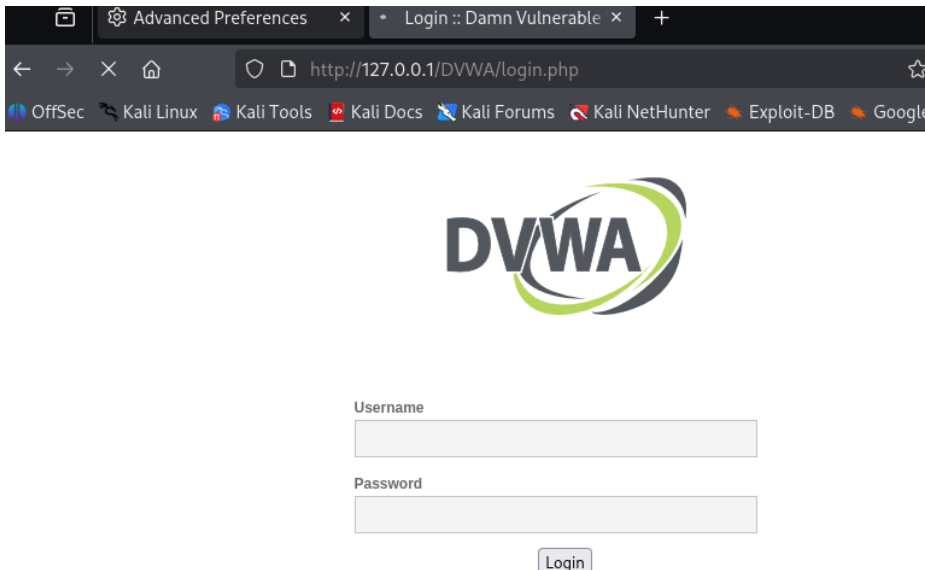
Рисунок 6: Изменение параметра браузера

2.7 Выполнение работы

Далее в Burp Suite я включаю кнопку Intercept, переключая её с off на on, и возвращаюсь к DVWA в браузере. В результате вкладка в Burp Suite меняется.



2.8 Выполнение работы



Advanced Preferences x Login :: Damn Vulnerable x +

← → × ⌂ ⛶ http://127.0.0.1/DVWA/login.php ☆

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google

DVWA

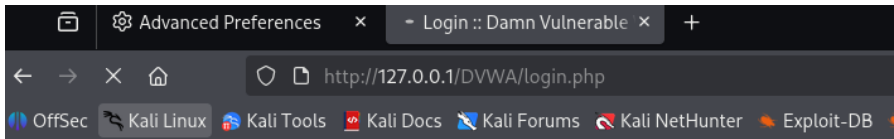
Username

Password

Login

2.9 Выполнение работы

Затем я пытаюсь ввести неправильные учётные данные для входа в DVWA и возвращаюсь в Burp Suite. Теперь он отображает вкладку, содержащую информацию о моей попытке входа с неверным логином и паролем.



Username



2.10 Выполнение работы

Time	Type	Direction	Method	URL
10:39:12...	HTTP	→ Request	GET	http://127.0.0.1/DVWA/login.php
10:40:39...	HTTP	→ Request	POST	http://127.0.0.1/DVWA/login.php

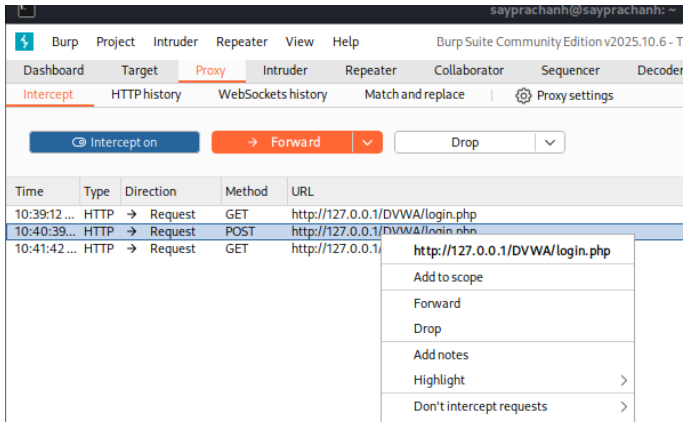
Request

Pretty Raw Hex

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 84
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DVWA/login.php
12 Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
```

2.11 Выполнение работы

Я отправляю информацию о моей попытке входа на вкладку Intruder. Я выделяю имя пользователя и пароль и выбираю позицию Add для добавления полезной нагрузки (payload) атаки, затем меняю тип атаки на Cluster bomb attack для выбора типа атаки на сайт.



2.12 Выполнение работы

1

2 × +

?

Cluster bomb attack

Start attack

Target

http://127.0.0.1

☒ Update Host header to match target

Positions

Add §

Clear §

Auto §

1

SSPOST /DWA/login.php HTTP/1.1

2

Host: 127.0.0.1

3

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

4

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate, br

7

Content-Type: application/x-www-form-urlencoded

8

Content-Length: 84

9

Origin: http://127.0.0.1

10

Connection: keep-alive

11

Referer: http://127.0.0.1/DWA/login.php

12

Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418

13

Upgrade-Insecure-Requests: 1

14

Sec-Fetch-Dest: document

15

Sec-Fetch-Mode: navigate

16

Sec-Fetch-Site: same-origin

17

Sec-Fetch-User: ?1

18

Priority: u=0, i

2.13 Выполнение работы

Поскольку мы выбрали 2 параметра полезной нагрузки (имя пользователя и пароль), я должен создать обе полезные нагрузки: сначала для имени пользователя. Я придумываю несколько имён, чтобы протестировать все варианты полезной нагрузки.

The screenshot shows the Burp Suite interface. On the left, the 'HTTP history' tab is active, displaying a list of requests. The first request is a POST to `/DVWA/login.php` with a status of 200. The request body is visible, showing a login attempt with a security warning. On the right, the 'Payloads' tab is active, showing the configuration for the selected payload. The 'Payload position' is set to '1 - hello', the 'Payload type' is 'Simple list', the 'Payload count' is 5, and the 'Request count' is 25. The 'Payload configuration' section shows a list of strings: 'admin', 'hello', 'test', 'myname', and 'test1234'. The 'Start attack' button is visible in the top right of the interface.

Cluster bomb attack Start attack

Target `http://127.0.0.1` ☒ Update Host header to match target

Positions Add \$ Clear \$ Auto \$

```
1 POST /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 84
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DVWA/login.php
12 Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
```

Payloads

Payload position: 1 - hello
Payload type: Simple list
Payload count: 5
Request count: 25

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste Load... Remove Clear Deduplicate

- admin
- hello
- test
- myname
- test1234

2.14 Выполнение работы

Затем я делаю то же самое для второго параметра, добавляя полезную нагрузку.

The screenshot shows the Burp Suite Community Edition v2025.10.6 interface. The 'Intruder' tab is active, displaying a 'Cluster bomb attack' configuration. The target is 'http://127.0.0.1' and the 'Update Host header to match target' checkbox is checked. The 'Payloads' panel on the right is open, showing a 'Simple list' of payloads with the following configuration:

- Payload position: 2 - 1234
- Payload type: Simple list
- Payload count: 5
- Request count: 25

The 'Payload configuration' section shows a list of strings used as payloads:

Action	Payload
Paste	hello
Load...	password
Remove	pass
Clear	1234
Deduplicate	12345

The main window also displays the HTTP request details for the selected attack, showing the request line and headers.

```
1 POST /DWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 84
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DWA/login.php
12 Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418
13 Upgrade-Insecure-Requests: 1
14 Sec-Fetch-Dest: document
15 Sec-Fetch-Mode: navigate
```


2.15 Выполнение работы

После завершения добавления полезных нагрузок я нажимаю Start attack и начинаю атаку. Burp Suite перебирает все полезные нагрузки, тестируя все возможные варианты для входа на сайт.

 2. Intruder attack of http://127.0.0.1

Attack ▾

Si

Results Positions

▼ Capture filter: Capturing all items ☐ Apply

▼ View filter: Showing all items

Request ^	Payload 1	Payload 2	Status code	Response r...	Error	Timeout	Length	Comment
0			302	21			482	
1	admin	hello	302	5			481	
2	hello	hello	302	12			482	
3	test	hello	302	4			481	
4	myname	hello	302	4			481	
5	test1234	hello	302	10			482	
6	admin	password	302	5			481	
7	hello	password	302	7			482	

2.16 Выполнение работы

После завершения процесса я выбираю результат. Во вкладке Response мы видим, куда произошло перенаправление после ввода пары логин-пароль. В данном случае пара test-hello перенаправила нас на login.php, то есть обратно на страницу входа — значит, эта пара не подходит.

Request	Payload1	Payload2	Status code	Response r...	Error
0			302	21	
1	admin				
2	hello				
3	test				
4	myname				
5	test1234				
6	admin				
7	hello				

Request	Response
1	Result 3 Intruder attack
2	Payload1: test
3	Payload2: hello
4	Status code: 302
5	Length: 481
6	Timer: 4

Request	Response
1	HTTP/1.1 302 Found
2	Date: Fri, 10 Apr 2026 07:59:19 GMT
3	Server: Apache/2.4.65 (Debian)
4	Expires: Thu, 19 Nov 1981 08:52:00 GMT
5	Cache-Control: no-store, no-cache, must-revalidate

2.17 Выполнение работы

Однако в случае пары admin-password произошло перенаправление на location index.php, который является домашней страницей DVWA — значит, эта пара подходит для входа.

Request	Payload 1	Payload 2	Status code	Response r...	Error	Timeout	Length	Com
0			302	21			482	
1	admin							
2	hello							
3	test							
4	myname							
5	test1234							
6	admin							
7	hello							

Result 6 | Intruder attack

Payload 1: admin
Payload 2: password
Status code: 302
Length: 481
Timer: 5

Previous
Next

Request	Response
netty	Raw Hex
POST /DVWA/login.php HTTP/1.1 Host: 127.0.0.1 User-Agent: Mozilla/5.0 (X11; Linux i686_32; rv:1.9.0.1) Gecko/20100101 Firefox/3.0.1 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.8 Accept-Encoding: gzip, deflate Content-Type: application/x-www-form-urlencoded Content-Length: 85	1 HTTP/1.1 302 Found 2 Date: Fri, 10 Apr 2026 07:59:19 GMT 3 Server: Apache/2.4.65 (Debian) 4 Expires: Thu, 19 Nov 1981 08:52:00 GMT 5 Cache-Control: no-store, no-cache, must-revalidate 6 Pragma: no-cache 7 Set-Cookie: PHPSESSID=298225436873b6c2186e7602935d3fe7; expires=Sat, 11 Apr 2026 07:59:19 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict 8 location: index.php

2.18 Выполнение работы

Затем я выбираю эту пару и отправляю её в Repeater. На вкладке Repeater я нажимаю Send, чтобы отправить запрос. В результате мы перенаправляемся на index.php.

The screenshot displays the Burp Suite Repeater interface. At the top, the 'Repeater' tab is selected among other options like Dashboard, Target, Proxy, Intruder, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Learn. Below the tabs, there's a toolbar with a 'Send' button, a 'Cancel' button, navigation arrows, a 'Follow redirection' checkbox, and a 'Burp AI' button. The target URL is set to 'http://127.0.0.1'.

The main area is divided into three panels: Request, Response, and Inspector. The Request panel shows a POST request to '/DWA/login.php' with various headers and a body. The Response panel shows an HTTP/1.1 302 Found response with headers indicating a redirect to 'index.php'. The Inspector panel on the right lists various attributes of the request and response, such as request attributes, query parameters, body parameters, cookies, headers, and response headers.

Request

```
1 POST /DWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 88
9 Origin: http://127.0.0.1
10 Connection: keep-alive
11 Referer: http://127.0.0.1/DWA/login.php
12 Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418
13 Upgrade-Insecure-Requests: 1
```

Response

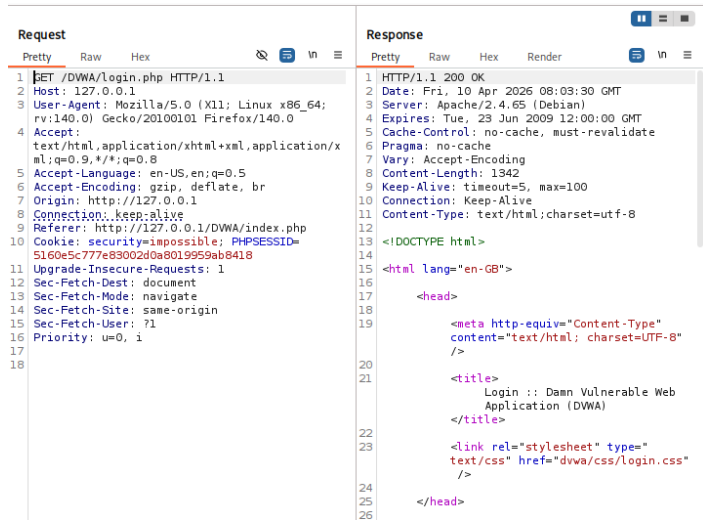
```
1 HTTP/1.1 302 Found
2 Date: Fri, 10 Apr 2026 08:02:58 GMT
3 Server: Apache/2.4.65 (Debian)
4 Expires: Thu, 19 Nov 1981 08:52:00 GMT
5 Cache-Control: no-store, no-cache, must-revalidate
6 Pragma: no-cache
7 Set-Cookie: PHPSESSID=df2f217d9669c13848a5f49eabfb2fe8; expires=Sat, 11 Apr 2026 08:02:58 GMT; Max-Age=86400; path=/; HttpOnly; SameSite=Strict
8 Location: index.php
9 Content-Length: 0
10 Keep-Alive: timeout=5, max=100
11 Connection: Keep-Alive
12 Content-Type: text/html; charset=UTF-8
13
```

Inspector

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 4
- Request cookies: 2
- Request headers: 17
- Response headers: 11

2.19 Выполнение работы

Я нажимаю Follow redirection и получаю HTML-код в окне Response.



The screenshot displays the developer tools of a web browser, specifically the Network tab. The 'Request' pane on the left shows the details of the HTTP request to `/DVWA/login.php`. The 'Response' pane on the right shows the HTML response received from the server.

Request

```
1 GET /DVWA/login.php HTTP/1.1
2 Host: 127.0.0.1
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Origin: http://127.0.0.1
8 Connection: keep-alive
9 Referer: http://127.0.0.1/DVWA/index.php
10 Cookie: security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418
11 Upgrade-Insecure-Requests: 1
12 Sec-Fetch-Dest: document
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-User: ?1
16 Priority: u=0, i
17
18
```

Response

```
1 HTTP/1.1 200 OK
2 Date: Fri, 10 Apr 2026 08:03:30 GMT
3 Server: Apache/2.4.65 (Debian)
4 Expires: Tue, 23 Jun 2009 12:00:00 GMT
5 Cache-Control: no-cache, must-revalidate
6 Pragma: no-cache
7 Vary: Accept-Encoding
8 Content-Length: 1342
9 Keep-Alive: timeout=5, max=100
10 Connection: Keep-Alive
11 Content-Type: text/html; charset=utf-8
12
13 <!DOCTYPE html>
14
15 <html lang="en-GB">
16
17   <head>
18
19     <meta http-equiv="Content-Type"
20       content="text/html; charset=UTF-8"
21     />
22
23     <title>
24       Login :: Damn Vulnerable Web
25       Application (DVWA)
26     </title>
27
28     <link rel="stylesheet" type="
29       text/css" href="dwa/css/login.css"
30     />
31
32   </head>
```

2.20 Выполнение работы

Чтобы увидеть структуру сайта, я перехожу в подокно Render и вижу результирующую страницу.

The screenshot displays the Burp Suite interface. The top toolbar includes a red 'Send' button, a settings gear icon, a 'Cancel' button, and navigation arrows. A 'Burp AI' button is also present. The interface is split into two main panels: 'Request' on the left and 'Response' on the right.

Request Panel: It has tabs for 'Pretty', 'Raw', and 'Hex'. The 'Pretty' tab is selected, showing a list of request components numbered 1 through 18. The request is a GET to `/DVWA/login.php` over HTTP/1.1. Key headers include `Host: 127.0.0.1`, `User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0`, and `Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8`. The 'Cookie' header is `security=impossible; PHPSESSID=5160e5c777e83002d0a8019959ab8418`.

Response Panel: It has tabs for 'Pretty', 'Raw', 'Hex', and 'Render'. The 'Render' tab is selected, showing a visual rendering of the response. At the top is the DVWA logo. Below it are two input fields labeled 'Username' and 'Password', followed by a 'Login' button.

2.21 Выводы

Я научился использовать Burp Suite